Многоуровневая методика проактивного реагирования на кибератаки на основе графовых моделей

En **A Multi-Layer Technique for Proactive Response Against Cyber Attacks Based on Graph Models**

E. V. Doynikova,
PhD (Tech.), Research Fellow
doynikova@comsec.spb.ru

I. V. Kotenko,
Doctor of Technical Sciences, Professor
ivkote@comsec.spb.ru

Saint-Petersburg Institute for Informatics and Automation (SPIIRAS)

Saint-Petersburg ITMO University

The paper goal consists in the development of automated technique for security incident response based on the objective quantitative metrics. Implementation of the technique should decrease organization losses from cyber attacks. The paper evolves an approach to the automatic security incidents response. The approach is based on the data from open sources, analytical modeling and consideration of the hierarchical integrated set of heterogeneous security metrics. It also gives input data for the calculation of security metrics. Analytical models allow security monitoring, forecasting of attacker steps and calculation of security metrics. The results of the experiments that demonstrate an efficiency of the suggested technique and algorithms are provided.

Keywords: information security, cyber attacks, proactive incident response, countermeasures, security metrics, analytical modeling, attack graph, service dependency graph

Цель работы состоит в разработке автоматизированной методики реагирования на инциденты, основанной на объективных количественных показателях, реализация которой позволит снизить потери организаций от кибератак. Развивается подход к автоматическому реагированию на инциденты безопасности, основанный на данных из открытых источников, аналитическом моделировании и комплексе показателей защищенности. Использование данных из открытых источников позволяет решить проблему унификации и автоматизированного сбора входных данных, а также получить исходные данные для вычисления показателей защищенности. Приводятся результаты экспериментов, показывающие эффективность предложенной методики и алгоритмов.

Ключевые слова: информационная безопасность, кибератаки, проактивное реагирование на инциденты, контрмеры, показатели защищенности, аналитическое моделирование, граф атак, граф зависимостей сервисов, инцидент безопасности

Елена Владимировна Дойникова,
кандидат технических наук, научный сотрудник
doynikova@comsec.spb.ru

Игорь Витальевич Котенко,
доктор технических наук, профессор, заведующий лабораторией
ivkote@comsec.spb.ru

Санкт-Петербургский институт информатики и автоматизации Российской академии наук (СПИИРАН)

Санкт-Петербургский национальный исследовательский университет информационных технологий, механики и оптики (Университет ИТМО)

1. Введение

Компрометация кибератак может помешать достижению бизнес-целей организации. Управление безопасностью позволяет снизить риски компрометации до приемлемых, однако полностью устранить их невозможно, поэтому задача отслеживания и реагирования на инциденты безопасности не теряет своей актуальности [1–4].

В данной области существует большое количество решений, в том числе [5–14]. Существующие методики применяют различные модели и показатели для учета одного или нескольких из следующих аспектов:

- стоимостные и временные затраты на реализацию контрмер;
- информация об инцидентах безопасности;
- влияние контрмер на восстановление критичности активов;
- влияние контрмер на вероятность успешной реализации угроз;
- влияние контрмер на работоспособность системы в целом и др.

Каждое предложенное решение обладает своими преимуществами. Однако важно рассматривать задачу реагирования на компьютерные атаки в комплексе: от сбора и обработки разнородных неопределенных данных до выбора оптимальных контрмер из множества вариантов с уче-

том ограниченного времени. При этом в современных условиях, когда состав системы постоянно меняется, а атаки становятся все более изощренными, важно создавать адаптивные комплексные механизмы, которые позволят проактивно реагировать на компьютерные вторжения.

Цель данной работы состоит в разработке автоматизированной адаптивной методики проактивного реагирования на инциденты, основанной на объективных количественных показателях, реализация которой позволит снизить потери организаций от кибератак.

Представляется перспективным гибридный подход, объединяющий элементы реактивных и проактивных подходов. Развиваемое в данной работе решение включает комплекс моделей предметной области, показателей защищенности, с помощью которых можно отслеживать изменение характеристик защищаемых объектов, и методик оценки защищенности и выбора защитных мер (контрмер).

Применение открытых стандартов представления исходных данных (например, CVE, CPE, CCE, CVSS [15]) и открытых источников данных безопасности (например, *National Vulnerability Database* – NVD) позволяет осуществлять автоматический унифицированный сбор и обработку входных данных.

Аналитические модели предметной области и их взаимосвязи дают возможность совместно учитывать характеристики различных объектов оценки защищенности. Для достижения свойства адаптивности и получения наиболее точного на текущий момент времени результата оценки защищенности, а также реактивного реагирования на изменения состояния по защищенности, вводится обработка событий об изменениях состояния анализируемой системы и иерархическое разделение показателей на группы в зависимости от данных, используемых для их вычислений. Для проактивного реагирования на инциденты вводится статический режим методики выбора контрмер, позволяющий выбрать средства защиты для снижения уровня риска безопасности до приемлемого и последующего противодействия обнаруженным атакам при эксплуатации анализируемой компьютерной сети.

Новизна предлагаемого подхода и основанной на нем методики выбора контрмер заключается в комплексном взгляде на процесс выбора защитных мер с учетом различных процессов (от унифицированного автоматического сбора и обработки данных безопасности до формирования списка контрмер), выделении различных уровней выбора контрмер в зависимости от доступных данных безопасности, а также в специфике отдельных моделей и алгоритмов, реализующих разработанную методику.

Предполагается, что тщательный предварительный анализ на основе комплекса показателей, реактивная обработка новой информации и проактивное прогнозирование на основе результатов анализа позволят повысить качество систем управления безопасностью и снизить потери от компьютерных атак.

Различные элементы подхода к оценке защищенности и выбору контрмер, разрабатываемого авторами статьи, уже были опубликованы, в том числе модели, методики и алгоритмы вычисления отдельных показателей защищенности [3, 4, 16], методики оценки защищенности [17], общий подход к выбору контрмер [18].

В [18] была описана общая идея подхода к выбору контрмер; в данной статье развивается предложенный ранее подход к выбору контрмер:

- вводится многоуровневая методика выбора последних, уровни которой выделяются в соответствии с уровнем абстракции моделей, применяемых для выбора контрмер в статическом и динамическом режимах;
- описываются алгоритмы выбора контрмер, применяемые на каждом уровне методики;
- уточняются применяемые для выбора контрмер показатели;
- приводятся результаты экспериментов по валидации работы предложенной методики.

Статья организована следующим образом. Во *втором* разделе анализируются существующие исследования в области выбора контрмер. В *третьем* разделе описывается предлагаемая методика выбора контрмер. В *четвертом* – представлены результаты экспериментов, анализ предложенного исследования, его достоинств, ограничений и недостатков, а также описываются будущие исследования. В *заключении* приводятся краткие результаты работы.

2. Релевантные исследования

Вопросы выбора защитных мер рассматриваются в [5–14].

Методики на основе теории игр [5] подразумевают представление процесса защиты от компьютерных атак в виде игры, в которой игроками выступают атакующий и защищающийся. Их действия влияют на состояние защищенности системы. Каждый из них должен найти такую стратегию достижения своей цели, которая является оптимальной по стоимости и времени. Преимущество методик на основе теории игр состоит в возможности учета временного аспекта.

Методики принятия решений на основе логического вывода на графах атак [11] предполагают представление всех возможных путей атаки в виде графа для выделения наиболее критичных уязвимостей системы. Для них выбираются защитные меры с учетом минимальной стоимости. Недостатком таких подходов является то, что они, как правило, не учитывают побочного ущерба от реализации контрмер.

В [7, 12] предлагается выбор защитных мер в динамическом режиме на основе байесовских графов атак.

В [19] описывается методика определения общего уровня защищенности системы, затем используемого для сравнения уровня защищенности до и после внедрения защитных мер.

В [8, 10, 13, 14] предлагаются методики выбора контрмер на основе интегрального показателя, учитывающего ожидаемые потери и эффективность защитных мер. Выбирается набор контрмер, которые дадут наибольший выигрыш при наименьших затратах. В [8, 10] допол-

нительно учитывается побочный ущерб от реализации защитных мер. Преимущество таких подходов состоит в учете распространения ущерба через зависимости сервисов. Недостаток заключается в том, что не рассматриваются все возможные пути атаки и их вероятность.

В [6] используются экономические индексы для оценки возможных потерь и эффективности контрмер, а именно:

- выигрыш от реализации контрмеры;
- затраты на реализацию контрмеры;
- дополнительная польза от реализации контрмеры.

Преимущество таких методов состоит в установлении прямой зависимости между финансовыми затратами организации и потерями от атак.

Существующие работы рассматривают выбор контрмер с помощью различных показателей и учитывают различные аспекты и этапы выбора контрмер. Каждый из подходов имеет свои преимущества. Для объединения преимуществ разных подходов был разработан комплексный подход, отличающийся совместным применением комплекса показателей защищенности и взаимосвязанных моделей, что позволяет оценивать защищенность и выбирать защитные меры в любой момент времени с учетом всех доступных данных и режима работы системы. В данной статье описываются особенности моделей, методик и алгоритмов, введенных для автоматического адаптивного выбора контрмер.

3. Методика выбора контрмер

3.1. Общий подход

Методика выбора контрмер является частью подхода к управлению защищенностью системы, основанному на применении открытых стандартов и данных из открытых источников, на комплексе показателей защищенности и аналитическом моделировании [4, 17]. Подход включает сбор и обработку входных данных, означивание моделей предметной области с применением этих данных (идентификация риска) и вычисление показателей защищенности разных уровней (количественное оценивание и оценка риска). Результаты оценки риска применяются для выбора контрмер. Уровни исходного подхода выделяются в зависимости от доступных данных:

- топологический уровень учитывает данные о конфигурации сети;
- уровень атак – данные о возможных путях атак;
- уровень атакующего – данные об атакующих;
- уровень событий – данные об инцидентах безопасности;
- уровень контрмер – данные о характеристиках контрмер;
- уровень системы – данные об общем состоянии защищенности анализируемой системы.

На более высоком уровне выделяются статический уровень (топологический, атак, атакующего) и динамические уровни (событий), а также интегральные уровни (контрмер и системы).

В данной работе аналогично выделяется два верхних уровня методики выбора контрмер: статический и динамический. В соответствии с этим определяются статический и динамический режимы методики выбора контрмер. Статический уровень соответствует топологическому уровню, уровню атак и уровню атакующего общего подхода. Статический режим методики применяется на этапах проектирования, развертывания и эксплуатации системы. Динамический уровень соответствует уровню событий общего подхода. Динамический режим методики применяется на этапе эксплуатации системы. В статическом режиме выбираются защитные меры, которые позволят повысить общий уровень защищенности системы. В динамическом – меры, которые направлены на конкретную обнаруженную атаку. Например, мера «Идентификация и аутентификация» может быть реализована с использованием программного токена в статическом режиме методики. В динамическом режиме (при поступлении информации об инцидентах безопасности) этот токен может использоваться для активации многофакторной аутентификации.

При выборе контрмер на данный момент учитываются эффективность контрмеры *Efficiency* (разница между уровнем риска до $Risk_{Before}$ и после $Risk_{After}$ реализации контрмеры), стоимость контрмеры *Cost* и возможный побочный ущерб *CD*. Риск вычисляется с учетом вероятности атаки и ее разрушительного воздействия, с использованием моделей сети, атак и зависимостей сервисов [17]. Стоимость контрмеры включает собственную стоимость защитного средства, стоимость его установки и поддержки. Она определяется экспертным путем для всех доступных контрмер. Под побочным ущербом понимается негативное воздействие контрмеры на нормальное функционирование системы. Побочный ущерб вычисляется на основе графа зависимостей сервисов. Методики и алгоритмы вычисления показателя риска и показателей, применяемых при мониторинге защищенности, подробно рассмотрены в статье [17].

3.2. Модели

Как было отмечено ранее, в основе подхода лежит аналитическое моделирование. Применяются модели различных объектов предметной области, в том числе модели сети, зависимостей сервисов, атак, атакующего, событий и контрмер.

Для определения эффективности контрмер используется ***модель атак***, задаваемая в виде графа атак, являющаяся развитием ранее разработанных в [12, 19] моделей:

$$G = (A, L, \tau, Pc),$$

где A – множество узлов графа (атакующих действий);

L – множество связей ($L \subseteq A \times A$);

τ – множество кортежей, определяющих тип связи между узлами;

Pc – дискретные локальные распределения условных вероятностей атакующих действий.

Модель атакующих действий определим следующим образом:

$$A = (H, V, Sc, St, Pr),$$

где: H – атакованный хост, спецификация которого включает описание сервисов хоста (связь с графом зависимостей сервисов добавлена для одновременного учета распро-

странения ущерба через зависимости сервисов и вероятностного аспекта компрометации активов) и доступных контрмер;

V – использованная уязвимость;

Sc – атака, направленная на сбор информации о хосте;

Pr – вероятность того, что атакующее действие находится в состоянии St ($Pr \in [0, 1]$). Модель атак генерируется автоматически с использованием конфигурации сети и открытых баз уязвимостей. Она позволяет отслеживать текущую ситуацию по защищенности, учитывать влияние событий на состояние системы, определять предыдущие шаги атаки и прогнозировать последующие на основе субъективных знаний при отсутствии статистических данных.

Побочный ущерб определяется путем применения ***модели зависимостей сервисов*** в форме графа, являющейся развитием модели, представленной в [10]:

$$SG = (S, L, \varepsilon),$$

где S – множество узлов графа зависимостей сервисов (сервисов);

L – множество связей ($L \subseteq S \times S$);

ε – множество кортежей вида $<L_k, d_k>$, определяющих тип зависимости между сервисами, где $L_k \in L$, $d_k \in$ {И, ИЛИ}.

Связь определим следующим образом:

$$L = (s_i, s_j, W),$$

где $s_i, s_j \in S$;

$$s_j \in Det(s_i),$$

где $Det(s_i)$ – множество всех прямых потомков сервиса s_i (то есть сервисов, от свойств безопасности которых напрямую зависят свойства безопасности s_i);

W – весовая матрица, определяющая степень зависимости свойств безопасности взаимосвязанных сервисов (предка и потомка).

Модель сервиса определим как:

$$S = (T, Cr),$$

где T – тип сервиса (информационно-технологические активы, порт или программно-аппаратное обеспечение);

Cr – критичность сервиса ($Cr = [Cr(c)\ Cr(i)\ Cr(a)]$);

$Cr(c)$, $Cr(i)$, $Cr(a)$ – критичность сохранения свойств конфиденциальности c, целостности i и доступности a соответственно.

Для генерации модели зависимостей сервисов используются данные от сетевых сканеров. Критичности основных бизнес-активов и весовые матрицы заполняются вручную. Данная модель используется для автоматического определения полной критичности всех активов системы. Связь между графом атак и моделью зависимостей сервисов позволяет рассчитать ущерб, наносимый атакующими действиями, и побочный ущерб в результате применения защитных мер. Определение критичности активов, не представляющих прямой бизнес-ценности для организации, позволяет не пропустить узкие места системы при оценке защищенности и избежать побочного ущерба при реализации защитных мер.

Модель событий вводится для обработки инцидентов безопасности и реагирования на них в динамическом режиме работы анализируемой системы. С одной стороны, данная модель используется для реактивного реагирования на инцидент, а с другой – для проактивной обработки информации:

$$\{E_i\},\ E_i = (T_i, H_i, Te_i),$$

где T_i – время фиксации события;

H_i – хост, на котором произошло событие;

Te_i – тип события.

Данные о событиях поступают от системы мониторинга защищенности.

Модель контрмеры применяется для выбора оптимальных контрмер:

$$C = (V, P, M, Sc, AI, SI),$$

где V – уязвимость, против которой направлена защитная мера;

P – платформа или конфигурация, в которой применима защитная мера;

M – режим работы системы (статический или динамический);

Sc – область действия (подсеть/подграф/узел графа атак/хост/программное или аппаратное обеспечение/уязвимость);

AI – влияние на сетевую конфигурацию или граф атак (удаление/добавление/изменение узла/связи);

SI – влияние на граф зависимостей сервисов (удаление/добавление/изменение узла/связи).

На данный момент список доступных контрмер для сетевых объектов и их характеристики задаются вручную. Модель контрмеры связана с остальными перечисленными выше моделями: моделью атак, моделью сети и моделью зависимостей сервисов. Реализация контрмеры влияет на возможность реализации угроз и, соответственно, изменяет граф атак. Контрмера может повлиять на каждый из элементов графа тремя способами: удаление, добавление, изменение. Для отображения контрмер на граф атак необходимо связать их с угрозами различным свойствам безопасности. Это осуществляется на основе классификации угроз для конкретной системы по различным свойствам безопасности и определения соответствующих контрмер для них. Кроме того, реализация контрмер может изменить конфигурацию сети, что также изменяет граф атак, и может повлиять на граф зависимостей сервисов. Модификация всех этих моделей приводит к пересчету ряда показателей, что ведет к изменению уровня риска.

3.3. Методика и алгоритмы

Разработанный подход ориентирован на учет уязвимостей. Уровень риска сетевых объектов зависит от их наличия. Существуют как уже известные уязвимости (в эту группу входят уязвимости, которые необходимо устранить, и уязвимости, которыми можно пренебречь), так и еще не выявленные. В соответствии с этим в рамках разработанного подхода выделяется два верхних уровня (режима) методики выбора контрмер: статический и динамический. Решение об устранении или исправлении известных уязвимостей (и соответствующих угроз безопасности) принимается в статическом режиме методики выбора контрмер. Однако угрозы, основанные на использовании неизвестных ранее уязвимостей (уязвимостей нулевого дня), или маловероятные угрозы могут быть ус-

пешно реализованы в динамическом режиме работы анализируемой системы. Поэтому выделяется динамический режим методики выбора контрмер: в нем решение о применении контрмер принимается на основе тщательного отслеживания и обработки инцидентов безопасности.

В ***статическом режиме методики*** предлагается покрыть контрмерами все объекты (сетевые объекты на топологическом уровне и объекты графа атак на уровнях атак и атакующего) с неприемлемым уровнем риска (чья компрометация приведет к серьезным финансовым потерям). Алгоритмы, реализующие элементы методики, зависят от доступных данных и показателей защищенности. Схема ***статического режима методики*** приведена на рис. 1. Работа методики начинается с запуска процесса выбора контрмер. При этом подразумевается, что процесс оценки защищенности завершен и вычислены уровни риска. Методика включает алгоритмы топологического уровня, уровня атак и атакующего. Ее основные этапы описаны далее.

Первый этап методики состоит в *определении уровня вычислений* с учетом доступных в хранилище данных. Как уже упоминалась, в рамках подхода выделяется три статических уровня данных: топологический уровень, уровень атак и уровень атакующего. Эти уровни связаны иерархически от топологического уровня к уровню атак и уровню атакующего. Каждый следующий уровень данных дает более высокий уровень точности оценки защищенности (то есть позволяет вычислить риск точнее за счет учета большего количества данных безопасности). Этап включает в себя следующие шаги:

1) проверка доступных в хранилище данных;

2) если доступны данные топологического уровня – запуск первого потока вычислений для следующих этапов; если доступны данные уровня атак – запуск второго потока вычислений для следующих этапов; если доступны данные уровня атакующего – запуск третьего потока вычислений для следующих этапов и завершение этого этапа;

3) возврат на шаг 1.

Три параллельных потока вводятся для получения наиболее точного результата с учетом доступных данных в любой момент времени.

Второй этап методики состоит в *извлечении данных* в запущенном потоке (или потоках) с учетом уровня вычислений. На этом этапе из хранилища извлекаются данные для выбора контрмер, а именно доступные аналитические модели и показатели защищенности.

Третий этап состоит в *выборе контрмер* в запущенном потоке (потоках) с учетом уровня вычислений. Результат этапа – список выбранных для реализации контрмер. Результат зависит от того, когда был остановлен процесс выбора контрмер.

На рис. 2 приведена схема ***динамического режима методики***, в котором реализуются алгоритмы уровня событий. Его основные этапы приведены ниже.

Первый этап заключается в *ожидании событий*. Событие является сигналом того, что риски безопасности изменились. Изменение рисков может быть результатом как инцидентов безопасности, так и изменения сетевой конфигурации. При появлении события происходит переход к следующему этапу.

Второй этап методики заключается в *извлечении данных* из хранилища. Полученные данные включают информацию об инцидентах безопасности и пересчитанных рисках безопасности.

На ***третьем этапе*** методики осуществляется *выбор контрмер*. Если новые риски безопасности превышают заданный порог, запускается алгоритм выбора контрмер уровня событий. Затем происходит переход к первому этапу.

Работа методики завершается в случае поступления соответствующей команды.

Алгоритмы выбора контрмер любого уровня включают следующие основные этапы:

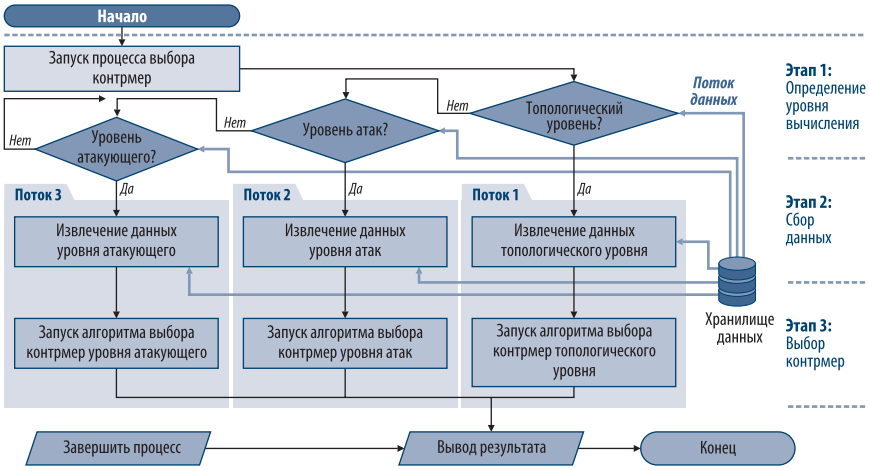


Рис. 1. ***Схема статического режима методики***

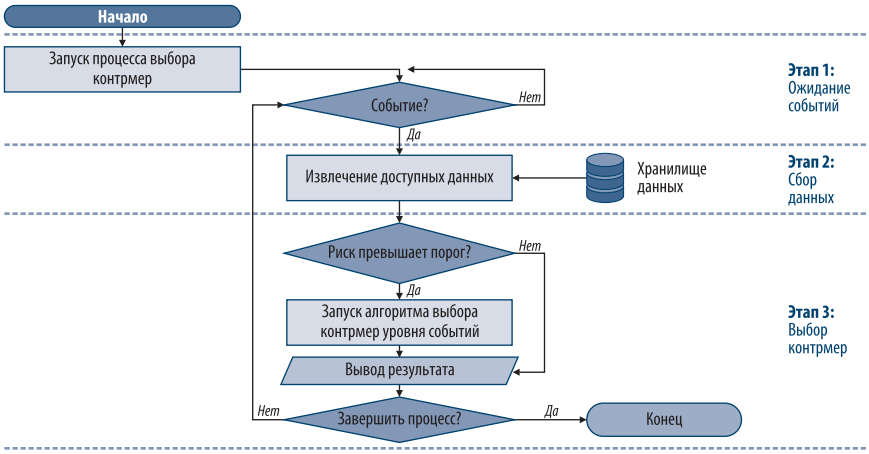


Рис. 2. ***Схема динамического режима методики***

1) реализация исправлений (патчей) с нулевой стоимостью (если такие существуют) для уязвимостей, порождающих неприемлемый уровень риска (уровень риска, превышающий заданный порог);

2) выбор контрмер с учетом их покрытия (области воздействия и затрагиваемых свойств безопасности) для оставшихся объектов (объектов сети или графа атак) с неприемлемым уровнем риска.

При определении области воздействия используется поле *Sc* модели контрмер. При определении затрагиваемых свойств безопасности используется показатель эффективности. Данный показатель задается трехмерным вектором $[CE_c\, CE_i\, CE_a]$, определяющим эффективность контрмеры с точки зрения конфиденциальности CE_c, целостности CE_i и доступности CE_a. Если $CE_c \neq 0$, то контрмера может использоваться против нарушения конфиденциальности. Если $CE_i \neq 0$, то контрмера может использоваться против нарушения целостности. Если $CE_a \neq 0$, то контрмера может использоваться против нарушения доступности.

Детальное описание алгоритмов выбора контрмер приведено ниже.

Основная идея алгоритмов состоит в рекурсивном покрытии всех объектов с неприемлемым уровнем риска. Вначале выбираются контрмеры с наибольшим покрытием. Критерием выбора контрмер является индекс выбора контрмер (*csi* = *Efficiency* – *Cost* – *CD*). Работа алгоритмов заканчивается, когда для всех объектов с неприемлемым уровнем риска выбраны контрмеры или когда обработаны все возможные контрмеры. Предлагаемые алгоритмы относятся к числу алгоритмов полного перебора с ограничениями.

Алгоритм статического режима методики выбора контрмер топологического уровня. Входными данными методики выбора контрмер топологического уровня являются:

- набор доступных контрмер;
- модель анализируемой компьютерной сети (включая программное и аппаратное обеспечение, и уязвимости);
- показатели защищенности топологического уровня (включая значения риска для уязвимостей, программного обеспечения и хостов, а также ущерб конфиденциальности, целостности и доступности при эксплуатации уязвимостей).

Область воздействия на топологическом уровне может включать (от максимального покрытия к минимальному): подсеть, хосты, программное и аппаратное обеспечение, уязвимости. К затрагиваемым свойствам безопасности относятся конфиденциальность, целостность, доступность и их комбинации. Эти свойства могут комбинироваться следующим образом (от максимального покрытия к минимальному): все свойства, два, одно, ни одного.

Алгоритм топологического уровня рекурсивен с точки зрения области покрытия – одни и те же действия выполняются для подсети и хостов, хостов и программного/ аппаратного обеспечения, программного/аппаратного обеспечения и уязвимостей. Предполагается, что максимизация индекса *csi* на подобласти воздействия контрмеры приведет к максимизации индекса в целом.

Алгоритм выбора контрмер топологического уровня включает 14 шагов.

Шаг 1. *Классификация контрмер* по области воздействия и затрагиваемым свойствам безопасности.

Шаг 2. *Выбор контрмер с областью воздействия «подсеть»* (максимальная область воздействия). Пример контрмеры – «добавить межсетевой экран».

Шаг 3. *Сортировка выбранных контрмер и формирование списков (контрмер).* Сортировка контрмер осуществляется с учетом их области воздействия (в данном случае подразумевается количество затрагиваемых хостов) и затрагиваемых свойств безопасности. Первая контрмера в списке должна иметь максимальное покрытие. Каждая следующая выбирается исходя из наибольшего несовпадения покрытий с предыдущей контрмерой. Если на любом этапе формирования списка контрмер ряд из них имеет одинаковое покрытие, создается дополнительный список. Шаги (4–14) выполняются для всех сформированных списков контрмер.

Шаг 4. *Выбор контрмер с областью воздействия «хост».* Пример контрмеры с областью воздействия «хост» – «удалить хост».

Шаг 5. *Выбор хостов, попадающих под действие контрмер с областью воздействия «подсеть»*, но при этом имеющих незащищенные свойства безопасности.

Шаг 6. *Выбор контрмер для этих хостов* с учетом максимального значения индекса *csi*. Для этого вычисляется индекс *csi* для всех возможных комбинаций контрмер, выбранных на шаге 4 (одна контрмера влияет на два свойства, две контрмеры влияют на два свойства и т. д.). Затем выбираются контрмеры с максимальным индексом *csi*.

Шаг 7. *Выбор хостов, не попадающих под действие контрмер с областью воздействия «подсеть».*

Шаг 8. *Сортировка контрмер* с областью воздействия «хост» с учетом затрагиваемых свойств безопасности (от максимального покрытия к минимальному).

Шаг 9. *Выбор контрмер, затрагивающих все свойства безопасности* хостов, выбранных на шаге 7. Если для одного и того же хоста доступно несколько контрмер, то для реализации выбирается контрмера с наибольшим значением индекса *csi*.

Шаг 10. *Выбор контрмер, не затрагивающих все свойства безопасности* для оставшихся хостов с учетом максимального значения индекса *csi*. Для этого вычисляется значение индекса *csi* для всех возможных комбинаций контрмер. Затем выбираются контрмеры с максимальным значением индекса *csi*.

Шаг 11. *Выбор контрмер с областью воздействия «программное/аппаратное обеспечение».* Примеры контрмер с данной областью воздействия: «удалить программное обеспечение», «обновить программное обеспечение». Для этого повторяются шаги 5–10 для данных контрмер и для экземпляров программного/ аппаратного обеспечения (вместо хостов). На шаге 5 выбираются экземпляры программного/аппаратного обеспечения, попадающие под действие контрмер с областью воздействия «подсеть» или «хост», но при этом имеющие незащищенные свой-

ства безопасности, на шаге 7 – не попадающие под действие контрмер с областью воздействия «подсеть» или «хост».

Шаг 12. *Выбор контрмер с областью воздействия «уязвимость».* Для этого повторяются шаги 5–10 для данных контрмер и для уязвимостей (вместо хостов). На шаге 5 выбираются уязвимости, попадающие под действие контрмер с областью воздействия «подсеть», «хост» или «программное/аппаратное обеспечение», но при этом имеющие незащищенные свойства безопасности. На шаге 7 выбираются уязвимости, не попадающие под действие контрмер с областью воздействия «подсеть», «хост» или «программное/аппаратное обеспечение».

Шаг 13. *Вычисление индекса csi для контрмер.* Вычисляется значение индекса *csi* для всех сформированных списков контрмер.

Шаг 14. *Выбор списка контрмер для реализации.* Для реализации выбирается список с максимальным значением индекса *csi*.

Выходные данные алгоритма – набор оптимальных контрмер для анализируемой сети.

Алгоритм статического режима методики выбора контрмер уровней атак и атакующего. Входными данными методики выбора контрмер уровня атак являются:

- набор доступных контрмер;
- модель анализируемой компьютерной сети;
- граф атак;
- показатели защищенности уровня атак (включая значения риска для узлов графа, ущерб конфиденциальности, целостности и доступности при эксплуатации уязвимостей).

Алгоритм выбора контрмер уровня атак идентичен алгоритму топологического уровня. Отличие состоит в том, что область воздействия на уровне атак может включать (от максимального покрытия к минимальному) подграф, узел графа атак и уязвимость.

На уровне атакующего дополнительно учитываются характеристики последнего. Отличие алгоритма данного уровня от алгоритма уровня атак состоит только в том, что меняются значения риска для узлов графа атак и набор корневых узлов графа атак.

Алгоритм динамического режима методики выбора контрмер уровня событий. Основная цель данного алгоритма состоит в выборе контрмер для противодействия обнаруженным атакам в зависимости от текущих и спрогнозированных шагов атакующего. Алгоритмы других уровней предназначены для выбора контрмер, которые повысят общий уровень защищенности системы.

В работе вводится показатель «глубина графа до критичных активов». Он позволяет учитывать время, доступное для выбора и реализации контрмер. Данный показатель определяется как количество узлов графа до актива с высоким уровнем критичности. Если значение данного показателя превышает заданное пороговое значение, возможно ожидание новых событий для уточнения оценок. В противном случае для реализации предлагается набор контрмер, сформированный с учетом доступных данных с соответствующей степенью точности.

Входными данными методики выбора контрмер уровня событий являются:

- набор доступных контрмер;
- модель анализируемой компьютерной сети;
- модель полученных событий;
- показатели защищенности уровня событий.

Алгоритм выбора контрмер уровня событий включает шаги, описанные ниже.

Шаг 1. *Выбор узлов графа атак с неприемлемым уровнем риска.*

Шаг 2. *Определение значения показателя «глубина графа до критичных активов».*

Шаг 3. Если значение, вычисленное на шаге 2, меньше порогового значения, то переход к следующему шагу, иначе – переход к шагу 7.

Шаг 4. *Сортировка контрмер.* Вначале выбирается контрмера, влияющая на наибольшее число узлов графа. Каждая следующая контрмера выбирается исходя из наибольшего несовпадения покрытий с предыдущей контрмерой. Если на любом этапе формирования списка контрмер несколько контрмер имеют одинаковое покрытие, то создается дополнительный список. Работа алгоритма продолжается, пока не будут покрыты контрмерами все узлы графа атак с неприемлемым уровнем риска или пока не будут рассмотрены все доступные контрмеры.

Шаг 5. *Вычисление индекса csi для всех сформированных списков.* Для этого пересчитывается уровень риска всех узлов графа. Если остаются узлы с высоким уровнем риска, то список контрмер исключается из рассмотрения.

Шаг 6. Если на шаге 5 все списки исключены из рассмотрения, то возврат на шаг 4 (новые списки генерируются начиная со следующей по количеству затрагиваемых узлов контрмеры). Иначе – переход к шагу 7.

Шаг 7. *Выбор списка контрмер для реализации.* Для реализации выбирается список с максимальным значением индекса *csi*.

4. Эксперименты и анализ их результатов

Для проведения экспериментов на языке Java был разработан прототип компонента реагирования на инциденты. Эксперименты проводились на рабочей станции с ОС Microsoft Windows, Intel Core i7 и 8 Гб оперативной памяти.

Эксперименты были проведены для трех сетей (10, 20 и 40 хостов), для различных смоделированных последовательностей атак и соответствующих последовательностей событий безопасности. Для проверки эффективности разработанной методики использовался показатель *Benefit* (выигрыш в случае реализации контрмер). Показатель вычисляется следующим образом:

$$Benefit = EL - Losses_{after},$$

где EL – потери организации в случае реализации анализируемой последовательности атаки, если контрмеры не будут реализованы, а $Losses_{after}$ – потери организации в случае реализации анализируемой последовательности атаки, если контрмеры будут реализованы.

Результаты экспериментов для сети 1 (10 хостов), сети 2 (20 хостов)

и сети 3 (40 хостов) приведены на рис. 3–5 соответственно.

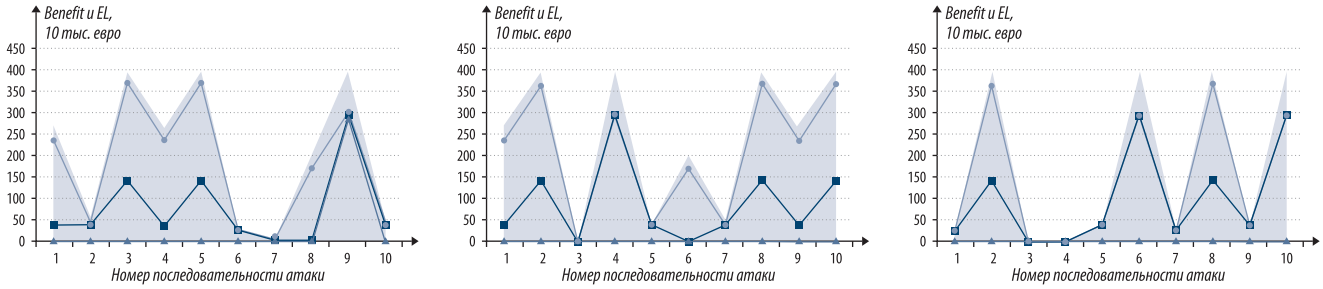
Эксперименты проводились для различных типов атакующих:

- *тип 1* – атакующий из внешней сети с высокими навыками (см. рис. 3 (а), рис. 4 (а), рис. 5 (а));
- *тип 2* – атакующий из внешней сети со средними навыками (см. рис. 3 (б), рис. 4 (б), рис. 5 (б));
- *тип 3* – атакующий из внешней сети с низким уровнем навыков (см. рис. 3 (в), рис. 4 (в), рис. 5 (в)).

Средняя длина последовательности атаки для экспериментов составила 6 шагов. На рисунках приведены результаты экспериментов для последовательностей атак, вызвавших хотя бы три события безопасности. На рис. 3–5 поверхность обозначает ожидаемые потери *EL* в случае, если контрмеры не будут реализованы. Линия с точками в виде кругов отражает ожидаемые потери в случае, если контрмеры будут реализованы после обработки первого инцидента безопасности. Линия с точками в виде квадратов обозначает ожидаемые потери в случае, если контрмеры будут реализованы после обработки второго инцидента безопасности. Линия с точками в виде треугольников – в случае, если контрмеры будут реализованы после обработки третьего инцидента безопасности.

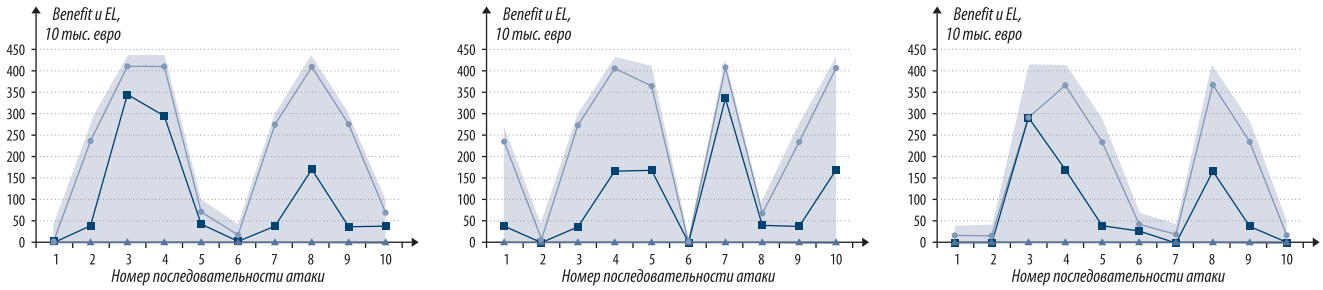
В соответствии с приведенными на рисунках графиками, наибольший выигрыш достигается в случае реализации контрмер после первого инцидента, поскольку уже в данный момент уровень риска превышает пороговое значение. Если контрмеры не реализовать на этом этапе, атакующий успевает скомпрометировать часть активов. Именно поэтому выигрыш при реализации контрмер после обработки второго инцидента значительно ниже.

В случае своевременной реализации контрмер уровень выигрыша стремится к уровню потерь в случае успешной атаки. Средний выигрыш для тестовых сетей составил 80 % по сравнению с ситуацией, когда контрмеры отсутствуют. Таким образом, реализация предлагаемой методики ведет к существенному снижению потерь, возникающих в результате кибератак.



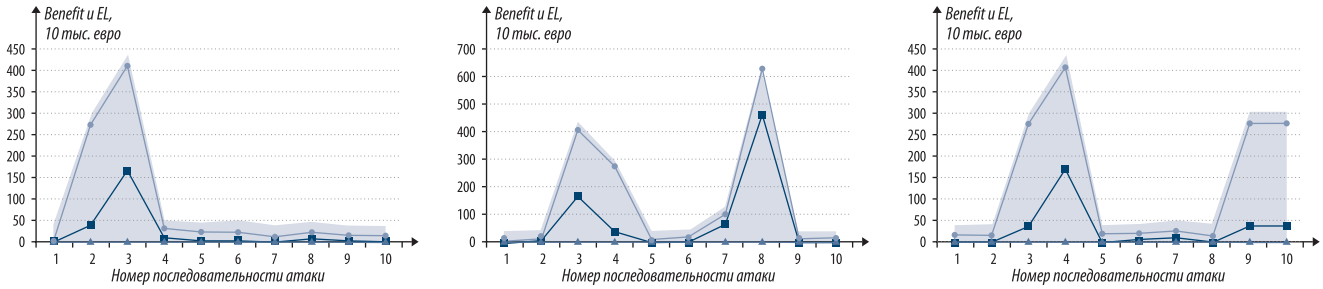
а *б* *в*

Рис. 3. ***Потери до реализации контрмер и выигрыш после реализации контрмер для сети 1 (а – для атакующего 1, б – для атакующего 2, в – для атакующего 3)***



а *б* *в*

Рис. 4. ***Потери до реализации контрмер и выигрыш после реализации контрмер для сети 2 (а – для атакующего 1, б – для атакующего 2, в – для атакующего 3)***



а *б* *в*

Рис. 5. ***Потери до реализации контрмер и выигрыш после реализации контрмер для сети 3 (а – для атакующего 1, б – для атакующего 2, в – для атакующего 3)***

Предложенный подход является частью комплексного решения по управлению безопасностью от этапа сбора и обработки разнородных неопределенных данных до этапа выбора контрмер. Его преимущество состоит в том, что он позволяет выбирать контрмеры на любом этапе функционирования системы с учетом доступных данных, от которых зависят применяемые алгоритмы выбора контрмер и учитываемые характеристики.

Другой отличительной чертой разработанного подхода является учет множества взаимосвязанных характеристик, что позволяет повысить точность выбора контрмер. В отличие от [5] предложенный подход позволяет уточнять характеристики и цели атакующего в динамическом режиме работы системы на основе результатов мониторинга безопасности. В отличие от [11] разработанный подход дает возможность учитывать динамический характер работы системы и точнее определять ущерб от реализации атак и контрмер. Существуют и другие подходы, которые позволяют учитывать динамический характер работы системы [8, 10, 11], но они не используют вероятности атакующих действий и инцидентов безопасности, а также характеристики атакующего. Некоторые подходы учитывают вероятности атакующих действий и инцидентов безопасности [12] и характеристики атакующего [7], но они не уделяют достаточного внимания стоимости активов и распространению ущерба (как прямого ущерба от реализации атакующих действий, так и побочного ущерба от реализации контрмер). В отличие от стоимостных моделей [6] предложенный подход учитывает особенности многошаговых кибератак.

Предложенное решение имеет ряд ограничений: так, генерировать списки контрмер для компьютерных сетей разного назначения и назначать возможные контрмеры различным объектам сети и узлам графа атак необходимо вручную. Кроме того, необходимо отметить сложность разработанных алгоритмов. Алгоритмы различных уровней методики должны запускаться параллельно для выбора контрмер с разным уровнем точности в зависимости от доступных данных и получения результата в любой момент времени. Система выбора контрмер должна генерировать и обрабатывать большое количество комбинаций доступных контрмер, причем для каждой комбинации она должна перестроить аналитические модели и пересчитать показатели защищенности.

Сложность алгоритмов компенсируется мощностью современных распределенных вычислительных систем. Алгоритмы каждого уровня методики могут быть запущены на разных процессорах. Это позволит получать результат выбора контрмер в любой момент времени с соответствующей степенью точности. Алгоритмы перестроения моделей и пересчета показателей защищенности для каждой комбинации контрмер также могут быть запущены на разных процессорах. Это позволит снизить время работы системы выбора контрмер до времени обработки одной комбинации контрмер.

На данный момент эксперименты были проведены только для одного типа сетевых конфигураций. Перечисленные выше недостатки планируется устранить в дальнейшей работе.

Заключение

В статье описаны элементы разработанной методики выбора контрмер и алгоритмы, реализующие ее отдельные шаги. Методика является частью предложенного ранее подхода к управлению безопасностью на основе аналитического моделирования. Подход включает в себя сбор и обработку входных данных, уточнение параметров аналитических моделей, оценку защищенности и выбор контрмер на основе комплекса показателей защищенности.

Предложенная методика позволяет выбирать защитные меры для снижения риска до приемлемого уровня в статическом режиме работы системы и выбирать контрмеры для обнаруженных атак в динамическом режиме работы системы. Разработанная методика является адаптивной, то есть алгоритмы выбора контрмер определяются доступными данными. Это позволяет получать результаты выбора контрмер в любой момент времени с соответствующей степенью точности и корректировать результаты с получением новых данных. Методика основана на учете взаимосвязанных данных безопасности из разных источников и вычислении комплекса взаимосвязанных показателей защищенности с использованием этих данных. Это позволяет повысить эффективность и качество выбора контрмер.

В статье описываются результаты экспериментов, доказывающие эффективность предложенного решения, а также анализируются присущие ему недостатки.

В дальнейшем планируется усовершенствовать и автоматизировать процесс генерации списков контрмер для разных сетевых конфигураций и различных типов угроз, а также создать собственную базу контрмер. Кроме того, планируется обучить систему выбора контрмер на основе обработанных данных об инцидентах безопасности для более эффективного реагирования на атаки. Также планируется расширить эксперименты на различные сетевые конфигурации и атаки. ■

Работа выполнена при финансовой поддержке РФФИ (проекты 15-07-07451, 16-37-00338, 16-29-09482 офи_м), гранта Президента РФ № МК-314.2017.9 и при частичной поддержке бюджетных тем № 0073-2015-0004 и 0073-2015-0007 в СПИИРАН.

ЛИТЕРАТУРА

1. Котенко И. В. Интеллектуальные механизмы управления кибербезопасностью // Управление рисками и безопасностью // Труды Института системного анализа Российской академии наук. – 2009. – Т. 41. – С. 74–103.

2. Котенко И. В., Саенко И. Б. Построение системы интеллектуальных сервисов для защиты информации в условиях кибернетического противоборства // Труды СПИИРАН. – СПб.: Наука. – 2012. – № 3 (22). – С. 84–100.

3. Kotenko I., Stepashkin M. Analyzing Vulnerabilities and Measuring Security Level at Design and Exploitation Stages of Computer Network Life Cycle // Lecture Notes in Computer Science. 2005. V. 3685. P. 311–324.

4. Kotenko I., Chechulin A. Attack Modeling and Security Evaluation in SIEM Systems // Internatio-

nal Transactions on Systems Science and Applications. V. 8, December 2012. P. 129–147.

5. Bursztein E., Mitchell J. C. Using strategy objectives for network security analysis // Information Security and Cryptology: Lecture Notes in Computer Science. 2010. V. 6151. Springer Berlin Heidelberg. P. 337–349.

6. Cremonini M., Martini P. Evaluating information security investments from attackers perspective: the Return-On-Attack (ROA) // Proceedings of the Fourth Workshop on the Economics of Information Security. 2005.

7. Dantu R., Kolan P., Cangussu J. Network risk management using attacker profiling // Security and Communication Networks. 2009. V. 2. № 1. P. 83–96.

8. Granadillo G. G., Debar H., Jacob G., Achemlal M. Individual countermeasure selection based on the return on response investment index // Proceedings of the 6th International Conference on Mathematical Methods, Models and Architectures for Computer Network Security (MMM-ACNS 2012): Computer Network Security, LNCS. Springer, St. Petersburg, Russia. 2012. V. 7531. P. 156–170.

9. Kanoun W., Cuppens-Boulahia N., Cuppens F., Araujo J. Automated reaction based on risk analysis and attackers skills in intrusion detection systems // Proceedings of Third International Conference on Risks and Security of Internet and Systems (CRISIS'08). 2008. P. 117–124.

10. Kheir N., Cuppens-Boulahia N., Cuppens F., Debar H. A service dependency model for cost-sensitive intrusion response // Proceedings of the 15th European Symposium on Research in Computer Security (ESORICS 2010). 2010. V. 6345. P. 626–642.

11. Lippmann R. P., Ingols K., Scott C., Piwowarski K., Kratkiewicz K., Artz M., Cunningham R. Validating and restoring defense in depth using attack graphs // Proceedings of MILCOM 2006. 2006. P. 1–10.

12. Poolsappasit N., Dewri R., Ray I. Dynamic security risk management using Bayesian attack graphs // IEEE Transactions on Dependable and Security Computing. 2012. V. 9. № 1. P. 61–74.

13. Strasburg C., Stakhanova N., Basu S., Wong J. S. Intrusion response cost assessment methodology // Proceedings of the 4th International Symposium on Information, Computer, and Communications Security. 2009. P. 388–391.

14. Wu Y.-S., Foo B., Mao Y.-C., Bagchi S., Spafford E. H. Automated adaptive intrusion containment in systems of interacting services // Computer Networks: The International Journal of Computer and Telecommunications Networking. 2007. V. 51. P. 1334–1360.

15. Котенко И. В., Дойникова Е. В. Анализ протокола автоматизации управления данными безопасности SCAP // Защита информации. Инсайд. – 2012. – № 2. – С. 56–63.

16. Kotenko I., Doynikova E. Security assessment of computer networks based on attack graphs and security events // Proceedings of the AsiaARES 2014 in conjunction with ICT-EurAsia 2014: Lecture Notes in Computer Science. Eds.: Linawati et al. Springer, Bali, Indonesia. 2014. V. 8407. P. 462–471.

17. Doynikova E., Kotenko I. CVSS-based probabilistic risk assessment for cyber situational awareness and countermeasure selection // Proceedings of PDP 2017. 2017. P. 346–353.

18. Котенко И. В., Дойникова Е. В. Методика выбора контрмер на основе комплексной системы показателей защищенности в системах управления информацией и событиями безопасности // Информационно-управляющие системы. – 2015. – № 3. – С. 60–69.

19. Чечулин А. А., Котенко И. В. Построение графов атак для анализа событий безопасности // Безопасность информационных технологий. – 2014. – № 3. – С. 135–141.

НОВОСТИ

Петренко С. А., Ступин Д. Д.

Национальная система раннего предупреждения о компьютерном нападении. – СПб.: ООО «ИД «Афина». – 2017.

ISBN 978-5-9909868-0-0

В монографии рассмотрены возможные решения актуальной научно-технической проблемы создания Национальной системы раннего предупреждения о компьютерном нападении на критически важные информационные ресурсы Российской Федерации. В их основе лежат научные результаты поисковых исследований авторов в области нано-, био-, инфо- и когнитивных технологий, а также ряд известных моделей и методов «вычислительного когнитивизма». Это позволило синтезировать сценарии раннего предупреждения и сдерживания оппонентов в киберпространстве России на сверхбольших объемах структурированной и неструктурированной информации от разнообразных источников Internet/Intranet и IoT/IIoT.

Монография будет полезна руководителям крупных государственных и коммерческих корпораций, директорам отечественных служб автоматизации (CIO) и служб информационной безопасности (CISO), инженерам-конструкторам и инженерам-исследователям в области информационной безопасности, а также преподавателям, аспирантам и студентам соответствующих специальностей.

Петренко Сергей Анатольевич – д. т. н., профессор, руководитель Центра информационной безопасности АНО ВО «Университет Иннополис». Конструктор более 20 национальных CERT и CSIRT. Эксперт секции по проблемам информационной безопасности научного совета при Совете Безопасности РФ.

Ступин Дмитрий Дмитриевич – к. т. н., доцент, заместитель генерального директора – руководитель комплекса инновационного развития и интеллектуальной собственности ОАО «Концерн «РТИ Системы». Заместитель заведующего кафедрой «Интеллектуальные информационные радиофизические системы» МФТИ.

Приобрести книгу можно в интернет-магазине на сайте www.inside-zi.ru или направив заявку в свободной форме по электронной почте podpiska@inside-zi.ru, или позвонив по телефону +7 (812) 347-74-12.